



Weekly IT Security Brief (Official-source-first) | 2026-04-19

06:01

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 8 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-34197(2026-04-30), CVE-2009-0238(2026-04-28), CVE-2026-32201(2026-04-28). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Cross-tenant helpdesk impersonation to data exfiltration: A human-operated intrusion playbook. Cross-tenant helpdesk impersonation to data exfiltration: A human-operated intrusion playbook
- Threat trend #2: Containing a domain compromise: How predictive shielding shut down lateral movement. Containing a domain compromise: How predictive shielding shut down lateral movement
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-34197

CVE Title	CVE-2026-34197 apache/activemq Unknown Type
CVE Description	Improper Input Validation, Improper Control of Generation of Code ('Code Injection') vulnerability in Apache ActiveMQ Broker, Apache ActiveMQ.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	apache/activemq, apache/activemq_broker
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-30
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-34197

CVE-2009-0238

CVE Title	CVE-2009-0238 microsoft/excel Unknown Type
CVE Description	Microsoft Office Excel 2000 SP3, 2002 SP3, 2003 SP3, and 2007 SP1; Excel Viewer 2003 Gold and SP3; Excel Viewer; Compatibility Pack for Word, Excel, and PowerPoint 2007 File Formats SP1; and Excel in Microsoft Office 2004 and 2008 for Mac allow remote attackers to execute arbitrary code via a crafted Excel document that triggers an access attempt on an invalid object, as exploited in the wild in February 2009 by Tro...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/excel, microsoft/excel_viewer, microsoft/office, microsoft/office_compatibility_pack, microsoft/office_excel
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-28
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2009-0238

CVE-2026-32201

CVE Title	CVE-2026-32201 microsoft/sharepoint_server Unknown Type
CVE Description	Improper input validation in Microsoft Office SharePoint allows an unauthorized attacker to perform spoofing over a network.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/sharepoint_server
Risk Score	6.5 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-28
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-32201

CVE-2012-1854

CVE Title	CVE-2012-1854 microsoft/office Unknown Type
CVE Description	Untrusted search path vulnerability in VBE6.dll in Microsoft Office 2003 SP3, 2007 SP2 and SP3, and 2010 Gold and SP1; Microsoft Visual Basic for Applications (VBA); and Summit Microsoft Visual Basic for Applications SDK allows local users to gain privileges via a Trojan horse DLL in the current working directory, as demonstrated by a directory that contains a .docx file, aka "Visual Basic for Applications Inse...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/office, microsoft/visual_basic_for_applications, microsoft/visual_basic_for_applications_sdk
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2012-1854

CVE-2025-60710

CVE Title	CVE-2025-60710 microsoft/windows_11_24h2 Unknown Type
CVE Description	Improper link resolution before file access ('link following') in Host Process for Windows Tasks allows an authorized attacker to elevate privileges locally.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/windows_11_24h2, microsoft/windows_11_25h2, microsoft/windows_server_2025
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2025-60710

CVE-2023-21529

CVE Title	CVE-2023-21529 microsoft/exchange_server Remote Code Execution
CVE Description	Microsoft Exchange Server Remote Code Execution Vulnerability
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	microsoft/exchange_server
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2023-21529

CVE-2023-36424

CVE Title	CVE-2023-36424 microsoft/windows_10_1507 Unknown Type
CVE Description	Windows Common Log File System Driver Elevation of Privilege Vulnerability
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/windows_10_1507, microsoft/windows_10_1607, microsoft/windows_10_1809, microsoft/windows_10_21h2, microsoft/windows_10_22h2
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2023-36424

CVE-2020-9715

CVE Title	CVE-2020-9715 adobe/acrobat_dc Use-After-Free
CVE Description	Adobe Acrobat and Reader versions 2020.009.20074 and earlier, 2020.001.30002, 2017.011.30171 and earlier, and 2015.006.30523 and earlier have an use-after-free vulnerability. Successful exploitation could lead to arbitrary code execution .
Root Cause	Memory-safety weakness can cause memory corruption or unintended control flow.
Exploitation Prerequisite	Victim must process malicious content (web page/file/packet).
Exploit Path	Delivery of malicious content -> memory fault trigger -> code execution / crash.
Affected Products	adobe/acrobat_dc, adobe/acrobat_reader_dc, apple/macos, microsoft/windows
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2020-9715



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-6105

CVE Title	CVE-2026-6105 待核實 Unknown Type
CVE Description	A security vulnerability has been detected in perfree go-fastdfs-web up to 1.3.7. This affects an unknown part of the file src/main/java/com/perfree/controller/InstallController.java of the component dolInstall Interface. The manipulation leads to improper authorization. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about this disclosure...
Affected Products	待核實
Risk Score	7.3 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6105

CVE-2026-6106

CVE Title	CVE-2026-6106 待核實 XSS
CVE Description	A vulnerability was detected in 1Panel-dev MaxKB up to 2.2.1. This vulnerability affects the function StaticHeadersMiddleware of the file apps/common/middleware/static_headers_middleware.py of the component Public Chat Interface. The manipulation of the argument Name results in cross site scripting. The attack may be launched remotely. The exploit is now public and may be used. Upgrading to version 2.8.0 is able to...
Affected Products	待核實
Risk Score	3.5 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6106

CVE-2026-6107

CVE Title	CVE-2026-6107 待核實 XSS
CVE Description	A flaw has been found in 1Panel-dev MaxKB up to 2.6.1. This issue affects some unknown processing of the file apps/common/middleware/chat_headers_middleware.py of the component ChatHeadersMiddleware. This manipulation of the argument Name causes cross site scripting. Remote exploitation of the attack is possible. Upgrading to version 2.8.0 is capable of addressing this issue. Patch name: 026a2d623e2aa5efa67c4834651e...
Affected Products	待核實
Risk Score	3.5 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6107

CVE-2026-6108

CVE Title	CVE-2026-6108 待核實 Unknown Type
CVE Description	A vulnerability was found in 1Panel-dev MaxKB up to 2.6.1. The affected element is the function execute of the file apps/application/flow/step_node/mcp_node/impl/base_mcp_node.py of the component Model Context Protocol Node. Performing a manipulation results in os command injection. The attack is possible to be carried out remotely. The exploit has been made public and could be used. You should upgrade the affected...
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6108

CVE-2026-6109

CVE Title	CVE-2026-6109 待核實 Unknown Type
CVE Description	A vulnerability was determined in FoundationAgents MetaGPT up to 0.8.1. The impacted element is the function evaluateCode of the file metagpt/environment/minecraft/mineflayer/index.js of the component Mineflayer HTTP API. Executing a manipulation can lead to cross-site request forgery. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized. The project was informed of th...
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6109

CVE-2026-1116

CVE Title	CVE-2026-1116 lolms/lollms XSS
CVE Description	A Cross-site Scripting (XSS) vulnerability was identified in the `from_dict` method of the `AppLollmsMessage` class in parisneo/lollms prior to version 2.2.0. The vulnerability arises from the lack of sanitization or HTML encoding of the `content` field when deserializing user-provided data. This allows an attacker to inject malicious HTML or JavaScript payloads, which can be executed in the context of another user&...
Affected Products	lolms/lollms
Risk Score	6.1 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-1116



Report B: Threat Intelligence News (last 7 days)

Headline: Cross-tenant helpdesk impersonation to data exfiltration: A human-operated intrusion playbook	
Source	Microsoft Security Blog
Published	Sat, 18 Apr 2026 12:55:45 +0000
Key Takeaway	Cross-tenant helpdesk impersonation to data exfiltration: A human-operated intrusion playbook
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/04/18/crosstenant-helpdesk-impersonation-data-exfiltration-human-operated-intrusion-playbook/

Headline: Containing a domain compromise: How predictive shielding shut down lateral movement

Source	Microsoft Security Blog
Published	Fri, 17 Apr 2026 14:51:01 +0000
Key Takeaway	Containing a domain compromise: How predictive shielding shut down lateral movement
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/04/17/domain-compromise-predictive-shielding-shut-down-lateral-movement/

Headline: CISA Issues Updated RESURGE Malware Analysis Highlighting a Stealthy but Active Threat

Source	CISA News
Published	Thu, 26 Feb 26 12:00:00 +0000
Key Takeaway	CISA Issues Updated RESURGE Malware Analysis Highlighting a Stealthy but Active Threat
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-issues-updated-resurge-malware-analysis-highlighting-stealthy-active-threat

Headline: Immediate Action Required: CISA Issues Emergency Directive to Secure Cisco SD-WAN Systems

Source	CISA News
Published	Wed, 25 Feb 26 12:00:00 +0000
Key Takeaway	Immediate Action Required: CISA Issues Emergency Directive to Secure Cisco SD-WAN Systems
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/immediate-action-required-cisa-issues-emergency-directive-secure-cisco-sd-wan-systems

Headline: Defending Your Enterprise When AI Models Can Find Vulnerabilities Faster Than Ever

Source	Mandiant Blog
Published	Thu, 16 Apr 2026 14:00:00 +0000
Key Takeaway	Introduction Advances in AI model-powered exploitation have demonstrated that general-purpose AI models can excel at vulnerability discovery, even without being purpose-built for the task. Eventually, capabilities such as these will be integrated directly into the development cycle, and code will be Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/global
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/defending-enterprise-ai-vulnerabilities/

Headline: The German Cyber Criminal Überfall: Shifts in Europe's Data Leak Landscape

Source	Mandiant Blog
Published	Wed, 15 Apr 2026 14:00:00 +0000
Key Takeaway	Figure 2: The number of German victims listed in data leak sites grew 92% in 2025 compared to 2024 While several factors influenced European ransomware trends in 2025, a striking contrast emerged in leak volumes. The resulting vacuum at the top of the ransomware market has led to a more crowded fiel Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	ALPHV, LockBit
Target	defense/europe
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/europe-data-leak-landscape/

Headline: Foxit, LibRaw vulnerabilities

Source Cisco Talos Blog

Published Thu, 16 Apr 2026 19:00:24 GMT

Key Takeaway Cisco Talos' Vulnerability Discovery & Research team recently disclosed one Foxit Reader vulnerability, and six LibRaw file reader vulnerabilities. The vulnerabilities mentioned in this blog post have been patched by their respective vendors, all in adherence to Cisco's third-party vulnerability dis Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/foxit-libraw-vulnerabilities/>

Headline: The Q1 vulnerability pulse

Source	Cisco Talos Blog
Published	Thu, 16 Apr 2026 18:00:31 GMT
Key Takeaway	Thor provides an overview of the Q1 2026 vulnerability statistics, highlighting key trends in legacy CVEs and the evolving impact of AI on the threat landscape. The Q1 vulnerability pulse Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ics/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/the-q1-vulnerability-pulse/

Headline: [Webinar] Eliminate Ghost Identities Before They Expose Your Enterprise Data

Source	The Hacker News
Published	Sat, 18 Apr 2026 13:37:00 +0530
Key Takeaway	In 2024, compromised service accounts and forgotten API keys were behind 68% of cloud breaches. Not phishing. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/04/webinar-find-and-eliminate-orphaned-non.html

Headline: \$13.74M Hack Shuts Down Sanctioned Grinex Exchange After Intelligence Claims

Source	The Hacker News
Published	Sat, 18 Apr 2026 13:29:00 +0530
Key Takeaway	Treasury Department in April 2022 for laundering funds linked to ransomware and darknet markets like Conti and Hydra. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cryptocurrency/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/04/1374m-hack-shuts-down-sanctioned-grinex.html

Headline: Tycoon 2FA Loses Phishing Kit Crown Amid Surge in Attacks

Source	SecurityWeek
Published	Sat, 18 Apr 2026 10:30:00 +0000
Key Takeaway	Threat actors are reusing Tycoon 2FA tools across other phishing kits following the platform’s disruption. The post Tycoon 2FA Loses Phishing Kit Crown Amid Surge in Attacks appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/tycoon-2fa-loses-phishing-kit-crown-amid-surge-in-attacks/

Headline: White House Chief of Staff to Meet With Anthropic CEO Over Its New AI Technology

Source	SecurityWeek
Published	Fri, 17 Apr 2026 19:00:00 +0000
Key Takeaway	White House Chief of Staff to Meet With Anthropic CEO Over Its New AI Technology - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data Breaches Fraud & Identity Theft Nation-State Ransomware Vu Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lat...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/white-house-chief-of-staff-to-meet-ith-anthropic-ceo-over-its-new-ai-technology/

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)